

SecurityGroup101 — Vendor Residual Risk Report

NIST SP 800-30 Rev. 1 · NIST SP 800-161 Rev. 1 Upd. 1 · NIST CSF 2.0 ID.RA · PCI DSS v4.0 Req 12.8 · GLBA Safeguards Rule

Assessment Date: July 2026 · Completed by: Maxine Jones, GRC Analyst — mkj00015@mix.wvu.edu · Reviewed by: Chief Information Security Officer

SECTION 1 — VENDOR IDENTIFICATION

Vendor Name	Stripe, Inc.
Service Provided	Payment processing SaaS platform — processes all SecurityGroup101 customer payment card transactions via API integration with production payment systems.
Risk Tier	Tier 1 — Critical (PCI-scoped payment card data, direct production API integration)
Business Owner	VP Finance, SecurityGroup101
Assessment Period	July 2026
Assessment Methods Conducted	(1) Full CAIQ v4 Self-Assessment Review (85 questions) · (2) SOC 2 Type II Report Review (period: Oct 2025 – Mar 2026) · (3) PCI DSS Level 1 Attestation of Compliance (AoC) Review

SECTION 2 — INHERENT RISK ASSESSMENT

Inherent Risk Score	28 / 38 (73.7%)
Inherent Risk Rating	HIGH
Inherent Risk Basis	HIGH inherent risk driven by: PCI-scoped payment card data (4 pts) · PII in customer billing records (3 pts) · Direct production API integration (3 pts) · Cloud-hosted SaaS delivery (2 pts) · Fourth-party subprocessors (AWS, Google Cloud) disclosed (2 pts) · Sole-source criticality for payment processing (2 pts). Offset: PCI DSS Level 1 Service Provider certification credit (–1 pt). Per NIST SP 800-161 Rev. 1 Upd. 1 Appendix E risk severity schema.

SECTION 3 — CONTROL EFFECTIVENESS ASSESSMENT

CAIQ v4 Overall Score	83 / 90 weighted points (92.2%) — LOW risk rating
SOC 2 Type II Report	Current report reviewed (period ending March 2026). Unqualified (clean) opinion issued. All Trust Services Criteria tested (Security, Availability, Confidentiality) with zero exceptions or qualified findings.
PCI DSS Compliance	Stripe is a PCI DSS Level 1 Certified Service Provider. Current Attestation of Compliance (AoC) reviewed and on file. Stripe's certification scope covers SecurityGroup101's use of Stripe's payment processing APIs.
Key Control Strengths	FIDO2 hardware token MFA for all privileged access · AES-256 at rest; TLS 1.3 in transit · Automatic AWS KMS key rotation · 72-hour breach notification SLA (contractually committed) · Data deletion on contract termination confirmed · Subprocessors (AWS, Google Cloud) disclosed · Right-to-audit clause in MSA

Open Findings	Finding 1 (Low — VRM-2026-001): Third-party data sharing register not yet completed (CAIQ DSP-09). Stripe committed to Q4 2026 remediation. Finding 2 (Informational — VRM-2026-002): Supply chain risks not yet formal line items in Stripe's risk register (CAIQ STA-06). Stripe Q3 2026 roadmap item.
Control Effectiveness Rating	STRONG

SECTION 4 — RESIDUAL RISK DETERMINATION	
Inherent Risk	HIGH
Control Effectiveness	STRONG
Residual Risk Rating	MEDIUM-LOW
Residual Risk Rationale	Stripe's inherent risk is HIGH due to PCI scope and sole-source payment processing criticality. However, Stripe's control environment is independently validated through PCI DSS Level 1 certification and an unqualified SOC 2 Type II opinion. Controls address all material risks identified in the inherent risk assessment. Two low-impact findings are tracked in the VRM POA&M and do not affect the risk decision. Residual risk reduced to MEDIUM-LOW. Per NIST SP 800-30 Rev. 1 Section 3.4: residual risk = inherent risk adjusted for the likelihood and impact reductions achieved by implemented controls.

SECTION 5 — RISK DECISION AND RECOMMENDATION	
Risk Decision	APPROVED WITH CONDITIONS
Approval Conditions	(1) Annual CAIQ v4 reassessment and SOC 2 Type II report review required. (2) POA&M items VRM-2026-001 and VRM-2026-002 tracked to closure by Q4 2026. (3) Stripe must provide 30-day advance written notice of any subprocessor additions or changes. (4) Right-to-audit clause maintained in Master Services Agreement.
Monitoring Plan	Quarterly: CISA Known Exploited Vulnerabilities (KEV) catalog monitoring for Stripe software dependencies. Annually: CAIQ reassessment + SOC 2 Type II report review + PCI DSS AoC review. Triggered: Out-of-cycle review upon any security incident, material change, or subprocessor addition.
Approved By	Chief Information Security Officer — SecurityGroup101
Approval Date	July 2026
Next Review Date	July 2027